

SRC-0028 - Executable Misuse Cases for Modeling Security Concerns

Jon Whittle, Duminda Wijesekera, Mark Hartong - ICSE 2008 - DOI 10.1145/1368088.1368106

Source type	Primary research / conference paper
Classification	documentation_plus_precise_scenario_behavior_model_required_or_created
Evidence	MUCSIM prototype; EVS and PTC preliminary case studies
Source hash	c281043bdf946742fe22c03cebbff96b0f4ff1276ace9bab0a4ac8a3870c51da
Permitted use	Pre-code executable scenario overlay; distinguish regression from proof

Research contribution

The paper formalizes misuse scenarios, keeps mitigation behavior separate as aspects, composes it automatically with functional behavior and executes known hostile traces against generated finite-state machines.

Core evidence boundary

Implemented: model weaving, FSM synthesis, animation and attack execution. **Not implemented or evaluated:** formal model checking, exhaustive security verification, automatic attack discovery or proof of threat completeness.

Documentation-first position

The technique can operate before code exists, but only after functional behavior has been represented as EIODs and sequence diagrams. It is not a raw-document analysis method.

Main input and output

```
functional goals and use cases
-> EIOD hierarchy and sequence diagrams
-> modification, attack and mitigation scenarios
-> graph-rule weaving and composed EIOD
-> communicating FSMs
-> attack execution result and regression evidence
```

Central DDTA reading

Executable misuse cases are a methodology-specific scenario overlay. Their strongest reusable idea is not formal verification, but preservation of separate security behavior plus repeatable regression of all known attacks after every mitigation change.

Method and model semantics

Required representations

- Level 1 EIOD: use cases and relationships.
- Level 2 EIOD: scenario nodes and control relationships.
- Level 3: UML sequence diagrams with participants, messages and fragments.
- Misuse relations: threatens and mitigates.
- Optional preconditions and postconditions for message semantics.
- Explicit or analyzed ordering for multiple aspect-weaving steps.

Typed hostile artifacts

- **Modification scenario:** optional attacker preparation that changes core behavior.
- **Attack scenario:** attacker interactions used as a test, not included in system behavior.
- **Mitigation scenario:** crosscutting aspect that adds, removes or restructures behavior.
- **Composed EIOD:** functional behavior after modification and mitigation weaving.
- **Generated FSMs:** executable behavior for the participants.

MATA weaving

MATA expresses each aspect as a graph rule. The left-hand side matches a behavioral context; the right-hand side creates or deletes elements. Sequence pointcuts match ordered message sequences, while an any fragment abstracts intermediate messages.

Order and scope

The threatens and mitigates links determine crosscutting scope. Multiple weaves may produce different results depending on order. The final order therefore remains a governed analytical input.

Operational procedure

- 1. Model core behavior as an EIOD.
- 2. Model an attack and optional attacker modification.
- 3. Compose modification aspects into core behavior.
- 4. Execute all known attack scenarios.
- 5. Design and weave a mitigation when an attack succeeds.
- 6. Regenerate FSMs and rerun the complete attack suite.
- 7. Add a more sophisticated attack and repeat.

The operational stopping point is that every currently modeled attack fails. This is not evidence that no unmodeled attack exists.

Execution, assurance and evaluation

What the execution means

An attack scenario defines event traces. It succeeds when those traces are admitted by the composed EIOD. In practice, events are injected into the animator. A failed attack execution shows prevention only for that modeled trace under the supplied model semantics.

Required distinction

```
formal trace semantics != implemented formal verification
animation != exhaustive state-space exploration
attack regression != proof of security
all known tests passing != threat completeness
```

Human-dependent evidence

- Attack selection and abstraction remain manual.
- Pre/postconditions or interactive path choices may resolve nondeterminism.
- The analyst chooses mitigations and determines whether residual risk is acceptable.
- Attack coverage depends on existing knowledge, expertise and the modeled system boundary.

Case-study results

Study	Input / scope	Reported result	Limit
EVS	9 design-level attacks from prior analysis	7 modelable	2 required storage/network detail
PTC	19 brainstormed high-level attacks	4 representative models	15 not individually modeled

The authors explicitly state that the studies validate only suitability and executability. They do not measure red-team benefit, effort, missed threats, comparative accuracy or improved security outcomes.

Temporal caveat

The separation, composition and regression concepts remain relevant. MUCSIM, UCSIM, MATA and the IBM Rational plug-in environment are historical and require current corroboration before making tool-maturity claims.

DDTA mapping and admissible claims

Base Analysis prerequisites

- Actors and functional goals.
- Use cases and ordered interaction scenarios.
- Participants, messages, conditions and interaction fragments.
- System boundaries and source assertions for every extracted fact.
- Explicit extracted-versus-inferred status and confidence.

Overlay artifacts and controls

- Separate core behavior, attacker modification, attack test and mitigation aspect.
- Typed threatens, mitigates, weave-scope and weave-order relations.
- Transformation rule, matched elements and generated-model version.
- Attack execution path, supplied conditions, result and reviewer disposition.
- Versioned regression suite rerun after model or mitigation changes.
- Deferred attacks with the missing storage, network, code or runtime evidence recorded.
- Later implementation evidence used to confirm or contradict the initial model.

Supported thesis claims

- Precise hostile scenarios can be executed against a requirements-level behavior model.
- Mitigation behavior can be preserved separately and composed automatically.
- Previously modeled attacks can form a repeatable regression suite.
- Requirements-level analysis cannot represent every storage, network or code-dependent attack.

Unsupported thesis claims

- MUCSIM formally verifies system security.
- Passing all attack tests proves the implementation secure.
- The method discovers all threats automatically.
- The two cases demonstrate superior red-team effectiveness.
- Heterogeneous documentation is sufficient without scenario-model construction.

Candidate DDTA evaluation measures

- Proportion of accepted attacks that can be represented at the current abstraction level.
- New regressions detected after mitigation or model changes.
- Weaving conflicts and ordering dependencies.
- Manual modeling and review effort per accepted finding.
- Agreement between model-level attack results and later code/test/runtime evidence.

Research gap retained

Whittle et al. start from precise scenario models. DDTA must still explain and evaluate how governed, versioned documentation becomes those neutral scenario views with assertion-level provenance, uncertainty, human review and incremental change impact.